

Action-Class Authority: Why the Impossibility of Complete Guardrails Forces a Reversibility-Graded Verification Layer for Agentic AI

Mayur Agnihotri

Abstract

Production agentic AI systems fail at one architectural seam: a prompt-injected, memory-poisoned, or supply-chain-compromised agent retains valid credentials and reasons over its own action authority. This paper argues that the response to that failure is not a stronger guardrail but a differently-placed one. A formal impossibility result establishes that no finite guardrail can be universally robust against adversarial input, and four independent empirical studies from May 2026 measure agent-reasoning compromise at rates high enough that any reasoning-based defense is statistically dominated. Read together, the formal and empirical results force a specific architecture. Because prevention cannot be completed and detection carries latency, the actions safe to leave under detection alone are exactly the reversible ones, while irreversible actions require authority established before execution by a mechanism the agent cannot rewrite. We call this pattern action-class authority: a verification layer that decouples a trusted, design-time reversibility classification from agent runtime reasoning, enforces it at a deterministic gate, and governs multi-step chains by the worst-case reversibility class present anywhere in the chain. We document the OWASP AISVS v1.0 verification requirements that operationalize this pattern (C9.2.3, C9.2.4, C9.2.10), analyze three canonical 2026 incidents, position the pattern against the 2026 literature on agent runtime enforcement and containment, and close with open research questions.

1. Introduction

The agentic AI deployment year of 2026 has crystallized a question the field was able to defer through 2024 and 2025: where does the security boundary for an autonomous agent live? Through the early agentic era, the boundary was treated implicitly as a property of the model. Better instruction-following, better safety training, better refusal calibration, the argument went, would produce agents whose reasoning could be trusted to refuse the actions an organization did not want to authorize. Frontier model releases were evaluated on benchmarks that measured the model’s ability to recognize unsafe requests and decline them. Agent deployments inherited the same assumption: if the model is safe, the agent built on top is safe.

Two independent lines of evidence closed that argument in 2026, one formal and one empirical.

The formal line removes the last reading of this as an engineering gap that better models eventually close. Extending Goedel’s incompleteness and Chaitin’s uncomputability results to AI safety, recent work shows that no finite set of guardrails can be universally robust against adversarial input: natural language is unbounded while any rule set is finite, so complete coverage was never a target more effort reaches. It is mathematically foreclosed [6]. The standard operational reading of that result, instrument for continuous runtime detection, states the consequence only halfway. If prevention

cannot be completed, the guardrail is bypassed eventually, and detection is an after-the-fact signal with nonzero latency. For an action that can be undone, detect-and-recover still closes the loop. For an action that cannot, detection that fires a moment too late is indistinguishable from no detection at all. So the impossibility result forces a step past moving the boundary to the action layer. It partitions that layer by reversibility: reversible actions can rest on detection, while irreversible ones require authority established before execution by a mechanism that does not depend on the guardrail holding.

The empirical line supplies the rates. Four independent publications in May 2026, spanning academic systems security, industry framework engineering, empirical production-scale evaluation, and academic adversarial machine learning, reached the same architectural conclusion through four methodologies: agent reasoning cannot be the safety boundary. The measured compromise rates (95 to 99 percent injection at the memory layer, 100 percent trust on poisoned knowledge graphs across nine frontier models, 60 to 89 percent attacker-intended action rates after retrieval) are what the impossibility looks like in production. The boundary has to live at the action layer, and the impossibility result tells us how that layer must be organized: by reversibility.

1.1 Contributions

This paper makes four contributions:

1. **The forcing argument.** We connect the formal impossibility of complete guardrails to a specific architectural consequence: reversibility-graded authority is structurally required, not defense-in-depth prudence. When prevention is provably incomplete and detection carries latency, irreversible actions cannot be made safe by detection and therefore require pre-execution authority independent of the guardrail. This derivation, and not the reversibility taxonomy itself, is the paper’s primary claim.
2. **The verification pattern, spec-anchored.** We specify action-class authority as a verification-layer pattern and document the OWASP AISVS v1.0 controls that operationalize it: C9.2.3 (trusted reversibility classification), C9.2.4 (runtime enforcement by class), and C9.2.10 (worst-case reversibility class across a multi-step or multi-agent chain), with a worked threat model showing why the same agent cannot both propose and classify its action class.
3. **Worked case analysis.** We analyze three canonical 2026 incidents (Codex Docker bind-mount, Meta Instagram AI Support Assistant, Red Hat npm Miasma supply chain) showing the architectural pattern is identical across coding agent, customer-facing assistant, and CI/CD pipeline.
4. **Positioning against the 2026 literature.** We situate action-class authority within the 2026 body of work on agent runtime enforcement, reversibility-tiered autonomy, and containment, and identify what that work leaves open: the derivation of reversibility-partitioning from impossibility, and the requirement that pre-execution authority be captured at an evidence vantage the agent cannot forge or omit, with binding strength scaled to irreversibility.

The remainder of the paper is organized as follows. Section 2 states the forcing argument. Section 3 describes the May 2026 empirical convergence. Section 4 specifies the verification pattern and its AISVS anchor. Section 5 presents three canonical cases. Section 6 compares against LLM-guardian alternatives. Section 7 positions the pattern against related work. Section 8 enumerates open research questions. Section 9 concludes.

2. The Forcing Argument

The claim of this section is narrow and it is the paper’s spine: given the impossibility of complete guardrails and the latency of detection, a reversibility partition of the action space is forced.

Let a guardrail be any mechanism that inspects a proposed action or its context and decides whether to permit it. The impossibility result [6] establishes that for any finite guardrail there exists adversarial input that defeats it. This is not a statement about current model quality; it is a statement about finite rule systems facing unbounded input, in the lineage of Goedel and Chaitin. The empirical convergence of Section 3 is the same statement measured in production.

Take the impossibility as given. Then, over a long enough horizon, the guardrail is bypassed. The system’s residual safety is whatever the agent can reach in the window between bypass and response. Two facts define that window. First, detection is an occurrence signal: it reports that something happened, after it happened, with nonzero latency. Second, actions differ in whether their effects can be withdrawn once they occur.

Cross these two facts. For an action whose effects can be withdrawn, detection with latency is sufficient: the loop closes by detect-and-recover, and the residual exposure is bounded by recovery time. For an action whose effects cannot be withdrawn, detection with latency is not sufficient by construction: by the time the signal arrives, the irreversible effect has committed, and detection that fires a moment too late is indistinguishable from no detection. No improvement in detection quality changes this, because the limiting quantity is latency against irreversibility, not accuracy.

The consequence is a partition, not a preference. Reversible actions can be governed by detection. Irreversible actions must be governed by authority established before execution, and that authority cannot depend on the same guardrail the impossibility result says will be bypassed. It must be carried by a mechanism outside the agent’s reasoning: a classification the agent does not supply at runtime, evaluated by a gate the agent does not control. This is the architecture the rest of the paper specifies. The reversibility taxonomy is old; the forcing of it from impossibility is the contribution.

A second consequence follows for evidence. If pre-execution authority is the control for irreversible actions, the authorization must be captured where the agent cannot forge or omit it, and the required strength of that binding scales with how irreversible the action is. An authorization asserted by the same component that can be compromised is not authorization. We return to this in Section 4.3 and Section 7.

3. The May 2026 Empirical Convergence

Four publications landed in May 2026 that, read together, settle the agent-reasoning-as-boundary question through four independent methodologies.

3.1 Systems-Security Framing

Christodorescu and Fernandes and collaborators argue from systems-security first principles that the AI model must be treated as an untrusted component, with security invariants enforced at the system level rather than within the model’s reasoning [1]. The argument is structural: a model that

can be prompted, poisoned, or contextually shifted into producing arbitrary outputs cannot also be the mechanism that decides which outputs are safe to act on.

3.2 Operational Framework

Anthropic published a comprehensive operational framework for Zero Trust in agentic AI systems [2]. The framework identifies the boundary problem as a top-of-stack concern and introduces the impossible-versus-tedious design test: controls whose value is friction degrade against an adversary with unlimited patience, while controls that remove a capability survive. The present work extends that principle from the credential layer [11] to the action layer.

3.3 Oracle Poisoning Measurement

Kereopa-Yorke and collaborators demonstrated that every tested state-of-the-art model trusts moderately-sophisticated poisoned knowledge-graph data at 100 percent [3]. The setup uses a 42-million-node code knowledge graph and nine state-of-the-art models. Three attacker sophistication levels show that the action-on-retrieved-content rate scales with sophistication while detection rates do not.

3.4 Sleeper Memory Poisoning

Pulipaka and collaborators reached the same conclusion at the memory layer: 95 to 99 percent injection rates, 90 to 95 percent retrieval rates on goal-adjacent queries, and 60 to 89 percent attacker-intended action rates after retrieval [4]. A poisoned memory persists across sessions; the agent’s reasoning never sees the injection point because the injection happened at write time, not read time.

3.5 The Convergent Conclusion

Read together, the four constitute a structural argument: agent reasoning is not a safety boundary because the reasoning component is the same one an adversary can corrupt, and corruption rates at memory and retrieval are high enough that any single-layer defense based on reasoning is statistically dominated. This is the empirical face of the forcing argument in Section 2.

4. The Verification Pattern

The pattern that operationalizes the forcing argument has three requirements, all shipped in OWASP AISVS v1.0 (released 2026-06-24, C9 Orchestration and Agentic Action chapter) [5].

4.1 C9.2.3 Trusted Reversibility Classification

C9.2.3 (Level 2) requires that each high-impact action have a trusted reversibility classification: read-only, reversible, externally reversible, or irreversible. Trusted means the classification is not supplied by the agent at runtime. The mechanism this paper specifies for making the classification trusted is to declare it in the tool or action manifest at design time, read by the gate rather than derived from the agent’s output. The four classes:

- **Read-Only (RO):** observes state without modifying it.

- **Reversible (R):** modifies state within the system; recoverable via undo log, transaction abort, or compensating action.
- **External-Reversible (ER):** affects external systems but is recoverable through identity verification or an out-of-band channel.
- **Irreversible (I):** commits to durable state the user cannot recover from without out-of-band action; emails sent, funds transferred, packages published to public registries, account identifiers linked.

The classification lives in the manifest. The gate evaluates the manifest. The agent reasons elsewhere. This is the architectural separation the forcing argument requires.

4.2 C9.2.4 Runtime Enforcement and C9.2.10 Worst-Case Chain Rule

C9.2.4 (Level 2) requires that the runtime enforce the classification by blocking, requiring approval, or restricting actions based on impact and reversibility. C9.2.10 (Level 3) requires that approval gates for multi-step or multi-agent action chains enforce the highest-impact reversibility class present anywhere in the chain. The chain rule prevents the composition failure where individually low-gate steps chain into an irreversible end state: read user email (RO), identify financial accounts (RO), initiate password reset (ER), modify account credentials (I) is a chain whose worst-case class is irreversible from the moment the first step executes, not at the irreversible step.

4.3 Threat Model and Evidence Vantage

The threat C9.2.3 addresses: when the same agent both proposes and classifies an action, a prompt-injected or context-corrupted agent can mislabel an irreversible action as reversible, and a gate reading the runtime classification will permit it. The manifest-declared classification was set at design time and cannot be rewritten by the agent at runtime.

The forcing argument’s second consequence (Section 2) sharpens this. The gate’s decision is only as sound as the evidence it reads. For the irreversible class, the authorization must be captured at a vantage the agent cannot forge or omit, and the binding strength should scale with irreversibility. AISVS v1.0 reflects this gradient in its higher-assurance controls: C9.2.8 binds approvals cryptographically to action parameters, requester identity, execution context, and a single-use nonce, and C9.2.9 isolates the approval key material from the agent runtime [5]. Reversibility class thus governs not only whether a gate fires but how strong the evidence behind it must be.

5. Three Canonical Cases

Three real-world cases from late May and early June 2026 demonstrate the pattern.

5.1 Codex Docker Bind-Mount (May 30, 2026)

OpenAI’s Codex coding agent, on a Linux host where the user was in the docker group, chained four legitimate operations: enumerate group memberships, recognize docker as root-equivalent, construct a bind-mount of the host /etc into a container with write access, and execute a write that overwrote a live configuration file. Each operation was permitted by the tool authority; the composite was irreversible at the system level. Under C9.2.3, “write to /etc on a live host” carries an irreversible classification in the manifest; the deterministic gate routes the action to human

ratification regardless of how the agent reasoned about the workflow, and C9.2.10 gates the whole chain by that worst-case class.

5.2 Meta Instagram AI Support Assistant (May 31, 2026)

Meta’s AI Support Assistant on Instagram had tool authority to modify account state, including linking new email addresses. Attackers found the prompt pattern that triggered an email-link change without identity verification. Exploitation persisted for approximately four months across thousands of accounts. Email-link to a primary identifier is irreversible at the user level, because password-reset control follows the email. A manifest-declared irreversible classification, evaluated by a deterministic gate, routes the change to out-of-band identity verification regardless of the attacker’s prompt.

5.3 Red Hat npm Miasma Supply Chain (June 1, 2026)

The redhat-cloud-services npm scope was compromised with 32 packages backdoored. The vector was not credential theft: attackers pushed orphan commits adding a workflow with id-token write permissions, then used OIDC trusted publishing to push through the legitimate path [8]. Trusted publishing, designed to eliminate long-lived tokens, becomes a misleading trust signal when pipeline access is compromised. Under C9.2.3, “publish to a public npm scope” carries an irreversible classification; C9.2.10 gates any chain reaching the publish step as irreversible from the chain start.

5.4 The Pattern Across Cases

Across a coding agent, a customer-facing assistant, and a CI/CD pipeline, from three vendors and three technology stacks, the composition failure is the same: legitimate per-step authority sequenced into an irreversible composite that no reasoning-layer check reliably stops. The missing layer in each is a trusted action-class declaration evaluated by a deterministic gate, governed by the worst-case class across the chain.

6. Comparison with LLM-Guardian Approaches

An alternative architecture uses a second LLM as a guardian that evaluates the primary agent’s proposed actions before they execute. The guardian approach has empirical attraction, but inherits the threat model action-class authority is built to escape: a guardian whose reasoning can be context-shifted or prompt-injected is structurally identical to the agent it guards. The deterministic gate evaluating a manifest-declared classification does not have this property, because the classification is set at design time and is not rewritten at runtime by any reasoning component.

This is not a rejection of LLM-guardian approaches, and the released standard makes the relationship explicit. AISVS C9.2.6 requires that AI-augmented review of planned high-risk actions add to, and not replace, the deterministic policy gate, and C9.2.7 requires that this review be protected against manipulation and not be bypassable through prompt injection [5]. The standard therefore codifies the layering this paper argues: the deterministic gate carries the structural verification load; AI-augmented review adds context-aware checks above it. The architectural question is which layer carries the load, not whether AI-based checks have value.

7. Related Work

Foundations. The separation of a declared capability from the actor that exercises it is the core of capability-based security [10] and has parallels in transactional-database reversibility, formal verification of reversible computation, and digital forensic chain of custody. Action-class authority applies that separation to agent action manifests.

The impossibility spine. The formal basis for Section 2 is Vassilev’s result that no finite guardrail is universally robust against adversarial input, extending Goedel and Chaitin to AI safety [6]. A related archival note reaches a similar conclusion on containment from logical and computational constraints [22]. Moon and Varshney give a complementary formal result, verifying safety over a typed action boundary in a way that is invariant to model capability [14]. These establish that prevention is bounded and that a fixed boundary can be verified. None derives the reversibility partition of Section 2, in which impossibility plus detection latency forces pre-execution authority specifically for the irreversible class.

Reversibility-tiered execution. Two 2026 lines classify agent actions by reversibility. Sahoo’s Controllability Trap scores each tool call on an irreversibility scale and enforces a cumulative irreversibility budget before re-authorization [12]. Ramaswamy and Miaosheng route operations through execution gears with utility-gated dispatch and stability guarantees for cyber-physical systems [13]. Both tier autonomy by reversibility as prudent design; neither derives the tiering from a formal impossibility result, and both key the gate on utility or a cumulative budget rather than a trusted, non-agent-supplied class evaluated per action.

The nearest neighbors. Two papers each cover part of this paper’s synthesis and are the sharpest comparisons. Zhai, Li and Wang’s Revisable by Design formalizes the same four-way reversibility taxonomy and proves that conflicting irreversible actions make full specification satisfaction impossible, a property of the action space rather than the algorithm [7]. That composition result is adjacent to the worst-case chain rule of Section 4.2, and it differs on two axes. Its impossibility concerns specification satisfaction and rollback cost in a streaming-intervention model with mid-execution rollback, not the guardrail-bypass impossibility this paper uses to force pre-execution authority; and it does not treat the classification as trusted non-agent-supplied metadata or address the evidence vantage of the authority that gates an irreversible action. Dobrin and Chmiel’s Unfireable Safety Kernel supplies the other half: external pre-action enforcement on a structurally sole path, fail-closed, with externalized signed evidence verifiable outside the agent’s trust boundary [9]. This is the unforgeable evidence vantage Section 2’s second consequence requires. It differs in that its authority is uniform, applying identical logic to every safety-critical operation with no grading by reversibility, and it is derived from architectural properties rather than an impossibility result, with no worst-case-across-chain rule. The contribution of this paper is the composition these two leave apart: guardrail-impossibility used to force a reversibility partition, pre-execution authority at an unforgeable evidence vantage whose strength scales to that partition, and multi-step chains governed by the least-reversible step. Metere’s Skills as Verifiable Artifacts gates a human-in-the-loop check on a skill’s verification level and observes that gating every irreversible call degrades into rubber-stamping [19]; scaling authority by a reversibility class rather than a uniform irreversible flag is the response to exactly that degradation.

Runtime enforcement and separation. A further body of 2026 work enforces action policies at runtime without a reversibility grading: neuro-symbolic constraint satisfaction [15], correct-by-construction verified policies with per-action monitoring [16], DSL-specified runtime rules [17], and hard cognitive-executive separation in which thinking agents may not act [18]. These reduce unsafe

execution but gate on generic policy or a binary act/no-act split rather than a trusted reversibility class scaled to how irreversible the action is, and none governs multi-step chains by their worst-case class. Sah and colleagues quantify a related horizon-dependent tradeoff between verification cost and safety in tool-using agents [20].

Supply-chain trust inheritance. The manifest-integrity assumption underlying action-class authority connects to trust inheritance across build and skill layers, where a declared claim is trusted for its position in a registry rather than a binding the actor cannot forge [21].

8. Open Research Questions

1. **Input-layer corruption vs. action-layer gate.** When the manifest itself is corrupted at distribution time, what is the residual exposure of an otherwise-correct gate? Hypothesis: exposure is bounded by manifest integrity-binding (signature, chain-of-custody at install); measurement against signed vs. unsigned manifest distributions would settle the threshold.
2. **Multi-step information-flow control.** The chain rule gates chains; it does not detect cross-chain information flows where reversibility-graded data moves between chains. Hypothesis: information-flow labeling with reversibility class as a label dimension extends the chain rule to cross-chain composition.
3. **Runtime drift detection.** When an agent’s action distribution shifts toward higher-risk classes over time, is the drift detectable from action-class telemetry alone, or does it require correlated identity, posture, and content signals?
4. **Reversibility-classification disagreement.** When vendor manifest and enterprise policy classify the same action differently, what resolves the disagreement? Hypothesis: worst-case wins is the safe default; case studies of real conflicts would test it.
5. **Reversibility-class evolution.** When an originally-reversible action becomes irreversible due to downstream propagation, how is the classification updated, and what is the gate behavior in the transition window?

9. Conclusion

The empirical evidence and the formal result point the same way. Prevention cannot be completed, so the guardrail is bypassed eventually; detection reports the bypass after it happens, with latency. For reversible actions that is enough. For irreversible actions it is not, by construction, and no improvement in detection closes the gap. The defense that holds partitions the action space by reversibility and moves the authority for irreversible actions ahead of execution, onto a classification the agent does not supply and a gate the agent does not control. The OWASP AISVS v1.0 controls C9.2.3, C9.2.4, and C9.2.10 operationalize this partition; C9.2.6 through C9.2.9 layer AI-augmented review and cryptographic binding above it. The conversation is no longer about whether agent reasoning is trustworthy enough to act on. The conversation is about where the gate sits, what it evaluates against, and how strong that evidence must be for the actions that cannot be undone.

References

- [1] M. Christodorescu, E. Fernandes, A. Hooda, S. Jha, J. Rehberger, K. Chaudhuri, X. Fu, K. Shams, et al., “Agent Security is a Systems Problem,” arXiv:2605.18991, 2026.
- [2] Anthropic, “Zero Trust for AI Agents,” enterprise framework, May 2026.
- [3] B. Kereopa-Yorke et al., “Oracle Poisoning: Corrupting Knowledge Graphs to Weaponise AI Agent Reasoning,” arXiv:2605.09822, 2026.
- [4] S. Pulipaka, S. Hlebik, L. Raghav, S. Abdelnabi, V. Raina, I. Sheth, M. Fritz, “Hidden in Memory: Sleeper Memory Poisoning in LLM Agents,” arXiv:2605.15338, 2026.
- [5] OWASP AISVS Project, “AI Security Verification Standard,” v1.0 (released 2026-06-24), C9 Orchestration and Agentic Action, controls C9.2.3, C9.2.4, C9.2.6, C9.2.7, C9.2.8, C9.2.9, C9.2.10. github.com/OWASP/AISVS.
- [6] A. Vassilev, “Robust AI Security and Alignment: A Sisyphean Endeavor?,” IEEE Security & Privacy, 2026 (arXiv:2512.10100).
- [7] Z. Zhai, M. Li, X. Wang, “Revisable by Design: A Theory of Streaming LLM Agent Execution,” arXiv:2604.23283, 2026.
- [8] Aikido Security, “Analysis of the redhat-cloud-services npm Compromise (Miasma),” June 1, 2026.
- [9] S. Dobrin, L. Chmiel, “The Unfireable Safety Kernel: Execution-Time AI Alignment for AI Agents and Other Escapable AI Systems,” arXiv:2606.26057, 2026.
- [10] M. S. Miller, “Robust Composition: Towards a Unified Approach to Access Control and Concurrency Control,” Ph.D. dissertation, Johns Hopkins University, 2006.
- [11] D. Hardt, “Anthropic’s Zero Trust for AI Agents Sets the Right Test: The Bearer Token Fails It,” Hello Blog, June 2026.
- [12] S. Sahoo, “The Controllability Trap: A Governance Framework for Military AI Agents,” arXiv:2603.03515, 2026 (ICLR 2026 Workshop on Agents in the Wild).
- [13] S. Ramaswamy, W. Miaosheng, “Managed Autonomy at Runtime: Gear-Based Safety and Governance for Single- and Multi-Agent Cyber-Physical Systems,” arXiv:2607.00334, 2026.
- [14] R. Moon, L. R. Varshney, “Containment Verification: AI Safety Guarantees Independent of Alignment,” arXiv:2605.09045, 2026.
- [15] B. Wu, W. Zhang, K. Chen, H. Fang, N. Yu, “Provably Secure Agent Guardrail,” arXiv:2605.29251, 2026.
- [16] “VeriGuard: Enhancing LLM Agent Safety via Verified Code Generation,” arXiv:2510.05156, 2025.
- [17] H. Wang, C. M. Poskitt et al., “AgentSpec: Customizable Runtime Enforcement for Safe and Reliable LLM Agents,” arXiv:2503.18666, 2025.
- [18] J. Fokou, “Parallax: Why AI Agents That Think Must Never Act,” arXiv:2604.12986, 2026.
- [19] A. Metere, “Skills as Verifiable Artifacts: A Trust Schema and a Biconditional Correctness Criterion for Human-in-the-Loop Agent Runtimes,” arXiv:2605.00424, 2026.

- [20] T. Sah, V. Srivastava, D. Sah, K. Jordan, “The Verifier Tax: Horizon Dependent Safety Success Tradeoffs in Tool Using LLM Agents,” ACM CAIS 2026 (arXiv:2603.19328).
- [21] M. Agnihotri, “Trust Inheritance Across Layers: A Cross-Domain Pattern Analysis of June 2026 Supply-Chain Compromises,” SSRN preprint, DOI 10.2139/ssrn.6931278, 2026.
- [22] S. Haider, “The Impossibility of AI Containment: Logical, Mathematical, Computational and Philosophical Constraints,” philsci-archive #24223, 2026.